

MedDefense Health Systems

Vulnerability Assessment Summary

Prepared by: **Threat Intelligence Analyst** | Prepared for: **James Chen, Deputy CISO** | Date: [assessment date]

■ **Navy bold** = report skeleton (fixed structure / section labels — reusable in any report) ■ **Maroon** = filled-in data (specific to this assessment)

1. Executive Summary

MedDefense engaged SecurePoint Consulting to scan its internal network and asked a direct question: do the ransomware groups profiled in our threat landscape work actually have something to exploit here? The answer is yes, and the details matter more than the number.

The scan found 31 issues. Four were labeled Critical, most were not. Labels alone are misleading: the single most dangerous item in this report — a confirmed, currently-active vulnerability on the server running our Electronic Health Record application — was labeled only "High" by the scanning tool, and was found only because an analyst manually followed up on a "Medium" clue the scanner itself couldn't fully resolve. Meanwhile, the patient database holding over 50,000 records is reachable, right now, from any of the roughly 350 devices on our network — no hacking tool required, just a network connection and a guessed or reused password.

Two of the systems this report examines have already been broken into before — the same billing server, twice, by two different kinds of attacker. One device — the MRI scanner's control workstation — runs an operating system with no security update since 2014 and cannot be patched, upgraded, or replaced this year; it can only be walled off from the rest of the network, which is a project this organization already approved and never finished building.

Bottom line: closing every genuinely urgent item found in this assessment costs approximately \$10,000 and requires no new budget request — it fits within funds MedDefense already has uncommitted this year. Fully addressing everything this report found, including the network architecture problems that make every one of these findings worse than it needs to be, costs roughly \$90,000, and this year's security budget has already been mostly allocated to a different, earlier set of priorities. Some hard choices, and one supplemental funding request, are recommended below.

2. Scope and Methodology

Scan Parameters: OpenVAS 22.x (Greenbone Community Edition), full and deep policy, authenticated where credentials were available (Linux via SSH, Windows via domain credentials); medical devices scanned unauthenticated. Scope: 10.10.0.0/16, all internal MedDefense subnets (Central, Westside, and VPN-connected Corporate HQ). Scan window: 02:00–06:00 to minimize clinical disruption. Executed by SecurePoint Consulting; 47 hosts responded during the scan window.

Tools and Sources Used Beyond the Raw Scan:

- **National Vulnerability Database (NVD)** — CVE research, CVSS vectors, CWE mapping, published/modified dates (Tasks 1, 12).
- **NIST CVSS v3.1 Calculator** — manual base-score deconstruction and environmental-metric recalculation (Tasks 2, 17).

- **CWE (MITRE)** — weakness taxonomy and Top 25 cross-referencing (Task 3).
- **Exploit-DB / searchsploit** — exploit maturity research for the five most critical CVEs, plus an automated `5-exploit_check.sh` script for repeatable service/version lookups (Tasks 4, 5).
- **CISA Known Exploited Vulnerabilities (KEV) Catalog** — confirmed active-exploitation status for six CVEs in this report (Task 4).
- **Lynis 3.0.9** — an independent, real security audit run against the analyst's own machine to build first-hand judgment of what a host-based scanner actually checks, then projected onto `billing-srv-01` (Task 8).
- **OSINT research** (vendor advisories, CISA alerts, Ubuntu/Canonical security notices) — vulnerabilities affecting MedDefense's technology stack that the scan itself could not see: FortiOS, Microsoft 365/Entra ID, Synology DSM, and two brand-new 2024 Apache CVEs directly affecting the exact vulnerable component already implicated in two prior real incidents (Tasks 9, 12).

***Limitations:** This scan does not cover Microsoft 365 (cloud services), mobile devices (iPads), or any asset offline during the scan window — this is a hard scope boundary, not an oversight. The scan is authenticated on Linux/Windows servers but unauthenticated on medical devices, so confidence in the medical-device findings is inherently lower. This is also a point-in-time snapshot — it reflects one night, and every day since increases the odds a newly disclosed vulnerability affects an unpatched system this report never checked.*

3. Findings Overview

Total findings: 31. The scan's own header claims 4 Critical / 7 High / 11 Medium / 5 Low / 4 Informational, but manual verification (Task 0) found this does not reconcile: the header was drafted before Finding 031 was appended as a manual addition by SecurePoint, meaning the true distribution is 4 Critical / 8 High / 10 Medium / 5 Low / 4 Informational.

Distribution by Sec+ 2.3 category (Task 7): Misconfiguration dominates at 13 of 31 findings (42%) — more than the next two categories combined — followed by Cryptographic (5), Web-based (4), Hardware/Firmware/EOL (4), Application (2), OS-based (2) and Supply Chain (1). Cloud-specific, Mobile Device, Virtualization and Zero-day categories show zero findings, but for three different reasons (scope exclusion, undocumented infrastructure, and a structural blind spot of signature-based scanning respectively) — not because MedDefense has no exposure in those areas.

False positive rate: 3 of 31 findings (≈9.7%), within SecurePoint's own stated typical range of 5–10% for this scan configuration (Task 11) — full documentation in Section 5 below.

4. Critical Findings

Full technical and contextual analysis for all five in Task 10; summarized here.

1. **Finding 031 — Ghostcat (CVE-2020-1938), CVSS 9.8, ehr-srv-01.** Confirmed active via manual verification, CISA KEV-listed, weaponized Metasploit module available. Sits on the application server for `ehr-db-01`, MedDefense's #1 Top-5 Critical Asset. The single most urgent finding in this entire report.
2. **Finding 003 — PostgreSQL Unrestricted Network Access, ehr-db-01.** No CVE, no exploit required — the patient database accepts connections from the entire internal network. Named explicitly, by ID, in Kill Chain #5 and independently in Scenario 3 from the 1x01 threat landscape work.

3. **Findings 001/002 — Apache RCE-to-Root Chain, billing-srv-01.** The only finding pair with confirmed, repeated real-world exploitation against MedDefense specifically (ransomware, then a cryptominer). Internet-facing.
4. **Finding 004 — Windows XP End-of-Life, MRI Workstation.** Three independently weaponized, KEV-listed RCEs (MS08-067, EternalBlue, BlueKeep) on a device that cannot be patched, upgraded or replaced this year.
5. **Finding 015 — NAS-01 Exposed Management Interface.** The organization's only backup copy, unencrypted, reachable network-wide — the literal final step of Kill Chain #1 and Scenario 1 ("Operation Flatline").

5. False Positive Report

Three findings were investigated and dismissed (Task 11), each with a documented validation method:

- **Finding 020** (CVE-2023-38408, OpenSSH on backup-srv-01) — requires ssh-agent forwarding to an attacker-controlled host, an implausible usage pattern for a backup orchestration server; SecurePoint's own note flagged this, and this project independently confirmed the reasoning.
- **Finding 030** (TLS Certificate CN Mismatch, ehr-srv-01) — the report's own text states this is operational (IP-based access), not a security vulnerability; confirmed via certificate chain inspection reasoning.
- **Finding 022** (System Clock Skew, 47 seconds, ehr-srv-01) — far inside Kerberos' 5-minute default tolerance and any realistic log-correlation window; confirmed non-issue.

Validation methodology used throughout: configuration file review (sshd_config, pg_hba.conf-style checks), operational context assessment (does this server's actual role make the exploitation precondition plausible?), and direct comparison against protocol tolerance thresholds where applicable. This 3-in-31 rate (≈9.7%) sits squarely within SecurePoint's own stated expected range — a useful sanity check that this validation process neither over- nor under-corrected.

6. Vulnerability Profile

The category distribution (Section 3, full detail Task 7) tells a specific story about MedDefense's security maturity: **the organization is not primarily losing to sophisticated, novel attack techniques.** It is losing to defaults never changed (two separate databases bound to the entire network under the identical weakness pattern, CWE-1327), operating systems kept in production years past vendor support (four separate findings under Hardware/Firmware/EOL), and strong cryptography added without ever removing the weak options sitting alongside it (TLS 1.0 next to TLS 1.2; DES/RC4 next to AES). This is the same pattern the 1x00 Gap Analysis identified at the control level — heavily preventive, thin on detection and correction — showing up again here at the vulnerability level. The two genuine software-vulnerability categories (Application, OS-based) account for only 4 of 31 findings combined; misconfiguration and cryptographic hygiene issues outnumber them more than four to one.

7. Threat-Informed Prioritization

Raw CVSS scores alone would disorder this report's priorities. Task 17's environmental recalculation demonstrated this concretely: **Finding 029**, a Grafana path traversal on an unmonitored shadow-IT device at Westside, carries a base CVSS of only 7.5 and an "Informational" scanner label — but recalculates to an environmental **9.3** once the reality that nobody is watching this device is properly weighted, a 1.8-point swing invisible to any CVSS-only triage process. **Finding 007** (LDAP signing/SMBv1 on the domain controller, no CVE at all) shifts from an estimated 7.4 to 8.1 once the asset's Critical criticality is factored in.

The 1x01 threat landscape work changes the story further: **Finding 003** (PostgreSQL exposure) is named, independently, in two separate threat narratives written before this scan even existed — Kill Chain #5 and Scenario 3 both arrive at the identical technical detail (the database's reachability beyond `ehr-srv-01`) through two completely different attacker profiles (a compromised vendor session vs. an internal ransomware affiliate). When a single unremediated gap is the common denominator across independently-written attack narratives, that is stronger evidence of real-world inevitability than any single CVSS number can express — which is why Finding 003, not the highest-CVSS finding in the report, is assessed as the single most dangerous vulnerability MedDefense currently carries (Task 18).

8. Remediation Roadmap

Full detail in Task 20. Summary by horizon below.

Horizon	Timeline	Findings	Est. Cost
Immediate	24–48h	031, 003, 001, 002, 029	~\$7,000
Short-term	7 days	007, 015, 018, 026, 006, 009, 013	~\$3,000
Medium-term	30 days	004, 010, 019, 024, 028, 027, 023, 005	~\$38,500
Long-term	90 days	011, 016, 014, 008	~\$41,000
Total		24 findings	~\$89,500

Budget reality: the 1x00 Risk Treatment Decisions already committed ~\$80,400 of this year's \$120,000 security budget to that project's own priorities, leaving only ~\$39,600 uncommitted — and that remainder was already earmarked for antivirus coverage (GAP-005). The Immediate and Short-term horizons here (~\$10,000 combined) fit comfortably within that remainder with no new funding needed. The Medium-term horizon (~\$38,500, driven mostly by the ~\$30,000 MRI network segmentation) would consume nearly all of what's left, and the Long-term horizon (~\$41,000) has no funding source at all this cycle. **Recommendation:** fund Immediate + Short-term now from existing headroom; reallocate the remaining ~\$29,600 toward MRI segmentation (Finding 004) ahead of GAP-005's antivirus rollout, given this assessment's findings represent a stronger case for urgency; and request supplemental budget explicitly for the Long-term horizon rather than waiting for next year's cycle.

9. Validation Plan

Remediation is not complete until it is verified. For each horizon:

- Configuration changes** (e.g., Findings 003, 006, 007, 009, 013, 015, 018, 019, 023): re-run the specific OpenVAS plugin or a targeted manual check (e.g., `psql` connection attempt from an unauthorized host for Finding 003; `nmap` port re-check for Finding 006) against the exact finding, not a full re-scan, to confirm the specific configuration actually changed as intended.
- Patches** (Findings 001/002/026, via ESM enrollment): confirm package versions post-patch (`apt -show-versions` or equivalent) and re-run `searchsploit`/CVE lookups to verify the previously-matched CVEs no longer apply to the installed version.

- **Compensating controls** (Findings 004, 016, 010, 008, 014): verify network segmentation with an actual reachability test from outside the newly-restricted segment (e.g., confirm **WS-RAD-01** is no longer reachable from a general workstation on **10.10.1.0/24** after Control 1 is implemented) — a firewall rule that looks correct in configuration but isn't actually blocking traffic is a false sense of security worse than no control at all.
- **A full re-scan** of the **10.10.0.0/16** range, at minimum 30 and 90 days after this report, to confirm the Immediate/Short-term and Medium-term/Long-term items respectively were actually resolved and did not introduce new findings.
- **Re-run Lynis** on **billing-srv-01** specifically (with root privileges this time) once ESM enrollment and the Apache patch are complete, to independently confirm the projected findings from Task 8 no longer appear.
- **Independent confirmation** of the Finding 010 firmware discrepancy flagged in Task 15 — validate the actual BD Alaris firmware version and CVE applicability directly with BD or the device management console before closing that finding either way.

10. Next Steps

Vulnerabilities are identified, prioritized and mapped to threats. The next step is to design the defense strategy: select formal security controls using industry frameworks, build a risk register with quantitative analysis, and produce a 6-month security roadmap that the Board will fund.

Patch Briefing — One-Page Executive Version

Three weeks ago we didn't know what we had, who wanted it, or where the doors were left open. Now we do — and this week, three of those open doors get closed.

1. Our patient-records server has a confirmed, active flaw. An attacker who reaches it can read any file on the server — including the password that unlocks our patient database — without logging in at all. It's on the federal government's list of vulnerabilities already being actively exploited elsewhere. **Fix:** a configuration change, a few hours of IT time, under \$1,000.

2. Our patient database itself accepts connections from almost any device on our network. No hacking tool required — just network access and a guessed or reused password to reach 50,000+ patient records. **Fix:** one firewall rule, immediate, under \$1,000.

3. The billing server's software that let ransomware in, and later a cryptominer, is still unpatched — and still reachable from the internet. This isn't a theory; it's the same door, for a third time. **Fix:** an emergency support subscription plus a software update, about one week, \$1,000–\$10,000.

If we do nothing: any one of these gives an attacker a direct line to patient records or repeats an incident we've already lived through twice — this time potentially with the backup destroyed alongside it.

What we've built in three weeks: we went from not knowing our own network, to knowing exactly who targets healthcare and why, to knowing precisely where those threats and our actual weaknesses meet — three fixes, three days, under \$12,000, closing the gaps most likely to be used against us right now.